

Threat Analysis Report

รายงานวิเคราะห์สรุปกลุ่ม Threat Actor
“The Gentlemen Ransomware”
และเครื่องมือ EDR Killer “GentleKiller”

01/07/2026

TLP:CLEAR





สารบัญ

สารบัญ.....	2
บทสรุปสำหรับผู้บริหาร	3
Threat Actor Profiles	4
Tactics, Techniques, and Procedures (MITRE ATT&CK)	17
Indicators of Compromise (IoCs).....	22
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ.....	24
อ้างอิง (References).....	26



บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้เป็นการวิเคราะห์ภัยคุกคามจากกลุ่ม The Gentlemen Ransomware ซึ่งเป็นกลุ่มมัลแวร์เรียกค่าไถ่ที่เติบโตอย่างรวดเร็วในรูปแบบ Ransomware-as-a-Service (RaaS) โดยใช้กลยุทธ์การโจมตีแบบ Double Extortion ที่จะทำการขโมยข้อมูลสำคัญของเหยื่อออกไปก่อน จากนั้นจึงดำเนินการเข้ารหัสระบบเพื่อข่มขู่เผยแพร่หรือขายข้อมูลสู่สาธารณะหากองค์กรไม่ยอมจ่ายเงินค่าไถ่ตามที่กำหนด กลุ่มภัยคุกคามนี้มีความสามารถในการโจมตีข้ามแพลตฟอร์มได้อย่างหลากหลาย ครอบคลุมทั้งระบบปฏิบัติการ Windows, Linux และสภาพแวดล้อมเสมือนจริงอย่าง VMware ESXi

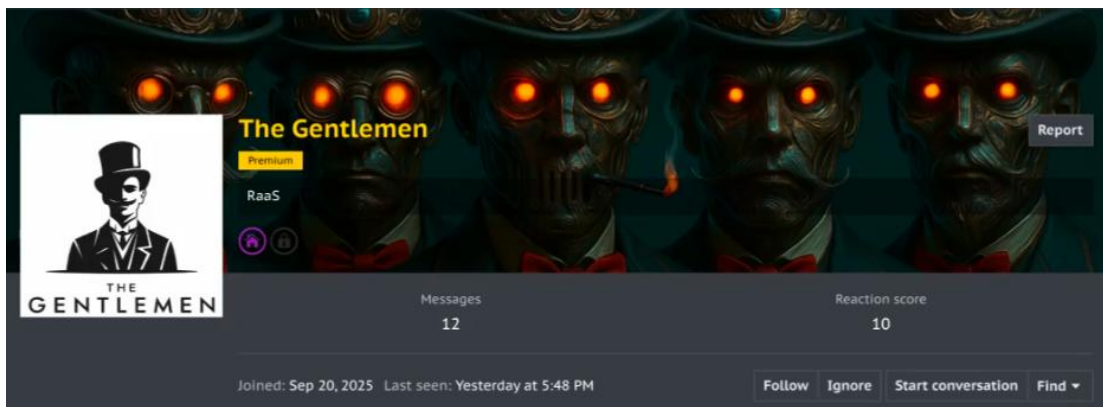
พฤติกรรมเด่นที่น่าจับตาของกลุ่มนี้คือการหลบเลี่ยงระบบป้องกัน โดยเฉพาะการพัฒนาและแจกจ่ายเครื่องมือ "GentleKiller" ให้แก่กลุ่มพันธมิตร (Affiliates) นำไปใช้ระงับการทำงานของระบบ EDR และ Antivirus (AV) ขององค์กรที่ตกเป็นเหยื่อ ซึ่งอาศัยเทคนิค BYOVD (Bring Your Own Vulnerable Driver) ในการโหลด Kernel Driver ที่มีสิทธิ์ระดับสูงที่สุด (Ring 0) เข้าไปควบคุมระบบและยุติกระบวนการทำงานของเครื่องมือความปลอดภัย โดยในปัจจุบันตรวจพบแล้วอย่างน้อย 8 รูปแบบที่ปรากฏตัวเป็นซอฟต์แวร์ถูกกฎหมาย

สำหรับสถานการณ์ผลกระทบในประเทศไทย ข้อมูลจาก Cyber Threat Intelligence (CTI) พบว่ามีองค์กรตกเป็นเหยื่อจาก The Gentlemen Ransomware แล้วมากกว่า 30 เหตุการณ์ โดยมีเป้าหมายส่วนใหญ่อยู่ในภาคบริการทางธุรกิจ และค้าปลีก ขณะที่สถิติในระดับสากลจาก Ransomware.live ระบุว่ามียาจำนวนเหยื่อสะสมรวมแล้วประมาณ 559 รายนับตั้งแต่ปี 2025 เป็นต้นมา สะท้อนให้เห็นว่าการดำเนินการของกลุ่มนี้เป็นภัยคุกคามระดับสากลที่มีความรุนแรงและสร้างความเสียหายในวงกว้างอย่างต่อเนื่อง

องค์กรจึงควรให้ความสำคัญอย่างสูงสุดกับการวางมาตรการเฝ้าระวังพฤติกรรมเสี่ยงในระบบ ได้แก่ การตรวจสอบการขโมยและส่งออกข้อมูล (Data Exfiltration) การตรวจจับการเข้าใช้สิทธิ์หรือบัญชีรายชื่อ (Credentials) ที่ผิดปกติ การเฝ้าระวังการเคลื่อนไหวที่น่าสงสัยภายในเครือข่าย การป้องกันการโจมตีหรือลบระบบสำรองข้อมูล (Backup) การตรวจสอบความพยายามโหลดไดรเวอร์ที่ผิดปกติเพื่อทำลายระบบรักษาความปลอดภัย (BYOVD) ตลอดจนการตั้งค่าแจ้งเตือนเมื่อเกิดเหตุการณ์การเข้ารหัสไฟล์จำนวนมากในระยะเวลาอันสั้น ทั้งนี้เพื่อลดโอกาสและบรรเทาผลกระทบจากการตกเป็นเป้าหมายโจมตีของ The Gentlemen Ransomware ในอนาคต



Threat Actor Profiles



ชื่อกลุ่ม / ชื่อที่ใช้ (Aliases)

The Gentlemen, The Gentlemen Ransomware

แรงจูงใจ (Motivations)

ดำเนินการเพื่อประโยชน์ส่วนตัว, ผลประโยชน์ทางการเงิน

ลักษณะการดำเนินการ

Double Extortion – ดำเนินการเข้ารหัสระบบของเหยื่อพร้อมทั้งขู่จะปล่อยข้อมูลของเหยื่อที่ถูกขโมยออกไปจากการโจมตี

RaaS – Ransomware as a Service โดยแบ่งส่วนแบ่งกับ Affiliate ในสัดส่วนที่สูง

ตรวจพบครั้งแรก

ถูกระบุว่าเป็นช่วงระหว่างกลางถึงปลายปี 2025

โน้ตเรียกค่าไถ่ (Ransom Note)

README-GENTLEMEN.txt

นามสกุลไฟล์หลังถูกเข้ารหัส (File extension)

.7mtzh



อุตสาหกรรมและประเทศเป้าหมาย

The Gentlemen กำหนดเป้าหมายไปยังภาคส่วนและประเทศต่าง ๆ ทั่วโลก ครอบคลุมทั้งทวีปอเมริกา ยุโรป และบางส่วนของเอเชียแปซิฟิก ในช่วงแรก กิจกรรมส่วนใหญ่จะจู่โจมอยู่ในภาคการผลิต บริการทางธุรกิจ และค้าปลีก แต่ภายในเดือนกุมภาพันธ์ 2026 กลุ่มเป้าหมายของกลุ่มนี้ได้ขยายไปยังเป้าหมายที่มีผลกระทบสูงกว่า เช่น ภาคการเงินและรัฐบาลของสหรัฐฯ รวมถึงองค์กรด้านการบินและองค์กรที่เกี่ยวข้องกับการบินในยุโรป

ภายในปลายเดือนมิถุนายน 2026 เหยื่อที่ถูกเปิดเผย ได้ขยายไปยังอุตสาหกรรมที่เกี่ยวข้องกับการป้องกันประเทศ ซึ่งเชื่อมโยงกับอุตสาหกรรมการผลิตทางทะเลและอิเล็กทรอนิกส์ของเยอรมนี รวมถึงองค์กรในสหรัฐอเมริกาสำหรับเอมิเรตส์และไต้หวัน ซึ่งครอบคลุมกลุ่มบริษัททางการเงินและบริการบูรณาการด้านไอที เป็นการตอกย้ำว่าการกำหนดเป้าหมายของผู้ก่อเหตุไม่ได้จำกัดอยู่เฉพาะภูมิภาคใดภูมิภาคหนึ่ง และสามารถเปลี่ยนเป้าหมายไปยังภาคส่วนต่าง ๆ ได้ในระยะเวลาอันสั้น

ประวัติโดยคร่าวของกลุ่ม

The Gentlemen เป็นกลุ่มมัลแวร์เรียกค่าไถ่ที่เริ่มปรากฏในช่วงปี 2025 และเติบโตอย่างรวดเร็วในรูปแบบ Ransomware-as-a-Service (RaaS) โดยมีการโฆษณาเครื่องมือและโมเดล affiliate ใน underground forum พร้อมเสนอส่วนแบ่งรายได้สูงให้กับผู้ร่วมปฏิบัติการ กลุ่มนี้ถูกจัดเป็นภัยคุกคามที่มีความสามารถในการโจมตีองค์กรขนาดใหญ่ และมีรูปแบบการดำเนินงานที่เป็นระบบมากขึ้นอย่างต่อเนื่อง

The Gentlemen ใช้กลยุทธ์ Double Extortion โดยขโมยข้อมูลสำคัญของเหยื่อก่อนเข้ารหัสระบบ จากนั้นใช้ข้อมูลที่ขโมยมาเป็นเครื่องมือกดดันให้เหยื่อจ่ายค่าไถ่ กลุ่มนี้ยังมีการปรับเปลี่ยนเครื่องมือระหว่างแคมเปญ เช่น การใช้เครื่องมือปิดระบบป้องกันเฉพาะสภาพแวดล้อมของเหยื่อ และการใช้เทคนิคเพื่อหลบเลี่ยงการตรวจจับในระบบองค์กร

The Gentlemen มุ่งเป้าไปยังองค์กรที่มีความเสี่ยงสูงต่อการหยุดชะงักของระบบ เช่น องค์กรภาคธุรกิจ ภาคการผลิต บริการสุขภาพ ประกันภัย ก่อสร้าง และหน่วยงานที่มีข้อมูลสำคัญจำนวนมาก โดยแนวโน้มการโจมตีสอดคล้องกับภาพรวม Ransomware ปี 2026 ที่มุ่งเป้าไปยังระบบองค์กร ระบบสำรองข้อมูล และโครงสร้างพื้นฐาน Virtualization มากขึ้น

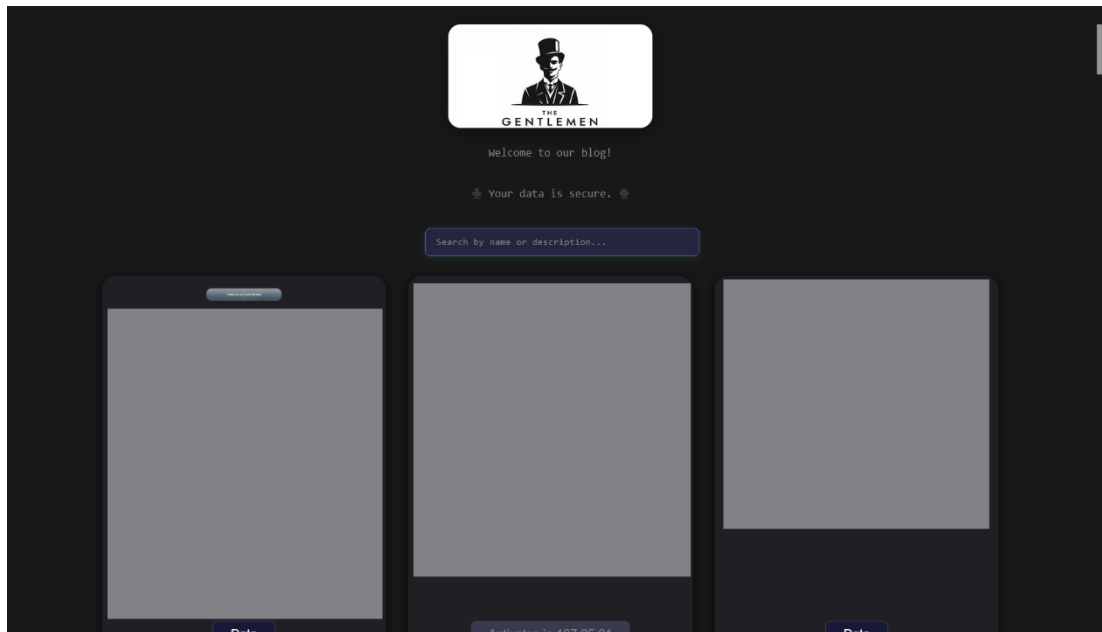
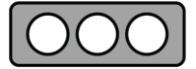


สถิติการโจมตีของกลุ่ม The Gentlemen

ภูมิภาคที่ถูกโจมตี	5 ประเทศที่ถูกโจมตีมากที่สุด	5 ภาคส่วนที่ถูกโจมตีมากที่สุด
เอเชีย	108 สหรัฐอเมริกา	58 ธุรกิจบริการ
ยุโรป	77 ไทย	30 ค้าปลีก
อเมริกาเหนือ	67 บราซิล	18 อุตสาหกรรมการผลิต
ละตินอเมริกาและแคริบเบียน	51 ฝรั่งเศส	15 การเงิน
แอฟริกา	10 อินเดีย	14 บริการสุขภาพ
ออสเตรเลียและนิวซีแลนด์	3	

ช่องทางออนไลน์ของกลุ่ม

แพลตฟอร์ม	ลิงก์
X Account	@TheGentlemen26
Onion leaks site	hxxp://tezwsse5czllksjb7cwp65rvnk4oobmzti2znn42i43bjdfd2prqqkad[.]onion/
SampleX	hxxps://smp10.simplex[.]im/a#Otp0TGDMNIj_QnXcvh9ABwFsiZEaZY_BovoanW59MXI
TOX ID	F8E24C7F5B12CD69C44C73F438F65E9BF560ADF35EBBDF92CF9A9B84079F8F04060FF98D098E
Breach Forums	hxxp://breachsfl6m2b52sznjg56r5wsy3jovh6vakzegbgjhwfpftwrkmsdad[.]onion//threads/the-gentlemens-raas.87167/
T1erOne	hxxp://tieronemkfevyizxcnt355agysp2iemvhon6iyiclwr7yuc7osgzgriid[.]onion/thread/15
Duty-Free	hxxps://dutyfreeb3wqm7ik3pjnaboubapqt3hzmzniuj7tqyoq5ij7jxqvowwwqd[.]onion/threads/7032/



tezwsse5czllksjb7cwp65rvnk4oobmzti2znn42i43bjdfd2prqqkad[.]onion



The Gentlemen X's Account



เครื่องมือที่มีการใช้งานในการโจมตี

1. Encryptor (Ransomware)

ใช้ Hybrid Encryption ร่วมกันระหว่าง Curve25519 (Key Management) และ XChaCha20 (Fast Stream Cipher)

1.1. **Gentlemen Encryptor (Go-based):** มุ่งเป้าโจมตีระบบปฏิบัติการ Windows โดยมีพีเจอร์แพร่กระจายตัวเองในเครือข่ายองค์กรผ่าน Active Directory (AD) และ GPO (Group Policy Object)

1.2. **ESXi Encryptor (C-based):** ออกแบบด้วยภาษา C เพื่อประสิทธิภาพสูงสุดในการเข้ารหัสระบบไฟล์บนสภาพแวดล้อม VMware ESXi โดยเฉพาะ

2. EDR/Anti-Virus Killer

2.1. **GentleKiller:** เป็น EDR Killer ที่ทาง Threat actor พัฒนาขึ้นเอง โดย ณ ปัจจุบันพบทั้งหมด 8 รูปแบบ โดยปลอมตัวเป็นโปรแกรมที่ถูกต้อง และใช้เทคนิค BYOVD ของไทรเวอร์จากซอฟต์แวร์แบรนด์ต่าง ๆ เพื่อหยุดการทำงานของ EDR

2.2. **HexKiller:** 3rd party EDR killer ซึ่งเดิมเคยถูกระบุว่าเป็นเครื่องมือเฉพาะของกลุ่มผู้ไม่หวังดีที่ใช้ชื่อว่า Warlock โดยเป็นเครื่องมือที่ใช้เทคนิค BYOVD ด้วยไทรเวอร์ของ Baidu Antivirus

2.3. **ThrottleBlood:** 3rd party EDR killer ที่พบบ่อยในการโจมตีของเครือข่ายกลุ่ม **MedusaLocker:** และพบได้ประปรายในกลุ่ม **DragonForce** ก่อนจะถูกเชื่อมโยงกับกลุ่ม Gentlemen ในเดือนกันยายน 2025 โดยยังคงเป็นเครื่องมือที่ใช้เทคนิค BYOVD ผ่านการอาศัยไทรเวอร์จาก TechPowerUp (ThrottleBlood.sys)

2.4. **HavocKiller:** 3rd party EDR killer ที่ถูกเปิดเผยต่อสาธารณะโดย Huntress ในวันที่ 19 มีนาคม 2026 แต่มีการตรวจพบว่าถูกนำมาใช้งานจริงในเคสแรนซัมแวร์ ตั้งแต่ **23 มกราคม 2026** และใช้เทคนิค BYOVD เหมือนกับเครื่องมืออื่น ๆ โดยอาศัยไทรเวอร์เสียงของ Huawei (havoc.sys)

3. Credential Stealing

3.1. **OxideHarvest:** Credential stealer ที่เขียนด้วยภาษา Rust สำหรับการขโมยข้อมูล Credential จากเบราว์เซอร์หลากหลายตัว (Chrome, Edge, Firefox, Brave) นักวิเคราะห์เชื่อว่า เป็นเครื่องมือที่ถูกพัฒนาโดยพันธมิตรภายนอกเนื่องจากภาษาที่ใช้พัฒนานั้น ไม่ใช่ภาษาหลักที่กลุ่มมักจะใช้งาน



ช่องโหว่ที่ใช้ในการโจมตี

1. CVE-2025-32433 (CVSS 10) - RCE vulnerability in Erlang/OTP SSH daemon
2. CVE-2025-55182 (CVSS 10) – RCE vulnerability in React Server Components (React2Shell)
3. CVE-2023-20198 (CVSS 10) - Allows a remote, unauthenticated threat actor to create an admin account on an affected system (Cisco IOS XE)
4. CVE-2024-21762 (CVSS 9.8) - Out-of-Bounds write in Fortinet FortiOS allows attacker to execute unauthorized code or commands via specifically crafted requests
5. CVE-2021-36260 (CVSS 9.8) - A command injection vulnerability in the web server of some Hikvision product
6. และอื่น ๆ ดังนี้ CVE-2024-36401, CVE-2022-40684, CVE-2016-4437, CVE-2023-46747, CVE-2021-26855, CVE-2025-33073, CVE-2021-27076, CVE-2022-41082, CVE-2023-27532, CVE-2023-32315, CVE-2022-27925

โดยส่วนมากผู้ไม่หวังดีเลือกใช้ประโยชน์จากช่องโหว่ระดับ Critical/High ของระบบต่าง ๆ เพื่อเป็นช่องทางเข้าถึงระบบเบื้องต้น (Initial Access) ไม่ว่าจะเป็นการเข้าควบคุมระบบโดยตรงผ่าน Remote Code Execution (RCE) หรือผ่านการ Bypass Authentication เพื่อยกระดับสิทธิ์ (Privilege Escalation) จากนั้นจึงขยายขอบเขตการโจมตีในเครือข่าย (Lateral Movement) เพื่อไปสู่การจารกรรมข้อมูล (Data Exfiltration) และการเข้ารหัสข้อมูลเพื่อเรียกค่าไถ่ (Ransomware Encryption) ในขั้นตอนสุดท้าย



GentleKiller

GentleKiller เป็นเครื่องมือสำหรับยุติการทำงานของ EDR (EDR killer) ที่พบได้บ่อยที่สุดใน การดำเนินการของกลุ่ม The Gentlemen ในขณะนี้ นักวิเคราะห์พบรูปแบบ (variant) ที่แตกต่างกันอย่างน้อย 8 รูปแบบ โดยแต่ละรูปแบบจะปลอมตัวเป็นผลิตภัณฑ์ที่ถูกต้องตามกฎหมาย ที่ต่างกัน และใช้ประโยชน์จากไดรเวอร์ที่มีช่องโหว่หรือไดรเวอร์ที่เป็นอันตรายแตกต่างกันไป แม้จะมีความแตกต่างในลักษณะภายนอก แต่สามารถจับกลุ่มตัวอย่างทั้งหมดไว้ภายใต้ ชื่อ GentleKiller เนื่องจากมีลักษณะการทำงานภายในที่คล้ายคลึงกันเป็นอย่างมาก

เมื่อตัดรายละเอียดเรื่องการปลอมแปลงและไดรเวอร์ที่ใช้แบบเฉพาะเจาะจงออก จะพบว่า โค้ดเบื้องหลังมีความเหมือนกันทั้งในด้านโครงสร้างและพฤติกรรม ซึ่งบ่งชี้อย่างชัดเจนว่ามี การใช้แม่แบบ (template) ในการพัฒนาชุดเดียวกัน แม่แบบนี้ถูกนำมาใช้ซ้ำในรูปแบบต่าง ๆ โดยมีการปรับแก้เพียงเล็กน้อยเท่านั้น ลักษณะของแม่แบบมีดังนี้

1. มีการใช้สตริง (strings) ที่เหมือนกันในทุกรูปแบบ
2. มีการยุติการทำงานของกระบวนการ (process) เป็นระยะในรูปแบบวนซ้ำ (loop)
3. มุ่งเป้าโจมตีโซลูชันด้านความปลอดภัยที่หลากหลาย
4. มีการใช้เทคนิคการอำพรางโค้ด (code obfuscation) แบบเดียวกัน

```
C:\work>Kasps.exe
=== Kaspersky 2026 Stariy Ded Edition ===

[*] Cleaning up previous d...
[+] Cleanup complete
[+] D dropped successfully
[+] D loaded
[+] Device opened successfully
[+] Starting monitoring loop (2s scan interval)...

[*] Scan #1...
[!] FOUND: VGAuthService.exe (PID: 2936)
[+] FIXED: VGAuthService.exe (PID: 2936)
[*] Checked 158 processes, fixed 1

[*] Scan #2...
[*] Checked 158 processes, fixed 0

[*] Scan #3...
[!] FOUND: SecurityHealthService.exe (PID: 3644)
[+] FIXED: SecurityHealthService.exe (PID: 3644)
[*] Checked 159 processes, fixed 1
```

ตัวอย่างการทำงานของ Gentlekiller



รูปแบบของ Gentlekiller และ Driver ที่ถูกใช้งานควบคู่กัน

ชื่อรูปแบบ	ชื่อไฟล์	ไดรเวอร์ที่ถูกใช้งาน
Kaspersky	Kasp<suffix>.exe	eb.sys , a rootkit
FACEIT Anti-Cheat	FaceIT<suffix>.exe	nseckrnl.sys , NSecsoft NSecKml driver
Valorant	Valorant<suffix>.exe	GameDriverX64.sys , an anti-cheat driver
Javelin	EAAntiCheat<suffix>.exe EASolo<suffix>.exe	stpm_(old new).sys , two vulnerable ProcessMonitor Driver samples by Safetica
WatchDog	BitD<suffix>.exe	dmx.sys , Zemana's WatchDog Antimalware Driver
Network Blocker	MB<suffix>.exe	360netmon_wfp.sys , a vulnerable driver by Qihoo 360 Technology
Cleaner	Deletor.exe	IMFForceDelete , IObit's IMF ForceDelete filter driver; the driver is dropped without the trailing .sys extension
G11	G11<suffix>.exe Symantec<suffix>.exe	PoisonX , a rootkit



รายชื่อผลิตภัณฑ์และกระบวนการที่เป็นเป้าหมาย

ผู้ให้บริการผลิตภัณฑ์	กระบวนการที่เป็นเป้าหมาย
Acronis	acronis_agent.exe, BackupAndRecoveryAgent.exe, managementagenthost.exe, mms.exe
AlienVault	alienvault-agent.exe, osqueryd.exe
Avast	afwServ.exe, aswEngSrv.exe, aswidsagent.exe, aswToolsSvc.exe, AvastSvc.exe, AvastUI.exe, avastsvc.exe, avastui.exe, bccavsvc.exe, wsc_proxy.exe
AVG	AVGUI.exe, AVGSvc.exe, avgnt.exe, avgsvca.exe, avgToolsSvc.exe
Binary Defense	BinaryDefenseAgent.exe
Bitdefender	Arrakis3.exe, BDAvScanner.exe, BDFsTray.exe, BDFileServer.exe, BDLived2.exe, BDLogger.exe, BDScheduler.exe, BDStatistics.exe, bdagent.exe, bdemsrv.exe, bdntwrk.exe, bdredline.exe, bdregsvr2.exe, bdservicehost.exe
Blumira	BlumiraAgent.exe
Bromium	BromiumDaemon.exe, BrDifxapi.exe
Carbon Black	cb.exe, cbcomms.exe, cbdefense.exe, carbonsensor.exe, RepMgr.exe
Cisco Talos	cfrutil.exe, CiscoAMPCEFWDriver.exe, cisco_amp_connector.exe, immunet.exe
CrowdStrike	ARWSRVC.EXE, ARCUpdate.exe, CSFalconContainer.exe, CSFalconService.exe, CSFalconUI.exe, csfalcondataprotect.exe, csfalcondaterepair.exe, REPRVC.EXE
Cynet	CynetEPS.exe, CynetMS.exe, CynetSvc.exe



Cybereason	ActiveConsole.exe, cybereason.exe, CybereasonActiveProbe.exe, CybereasonCR.exe
Cyvera	CyveraConsole.exe, CyveraService.exe, CyvrAgentSvc.exe, CyvrFsFlt.exe, cyvrfsflt.exe
Cylance/BlackBerry	CylanceSvc.exe
Darktrace	DarktraceTSA.exe
Deep Instinct	DeepInstinct.exe, DeepInstinctService.exe, DIAgentService.exe
Elastic	a2guard.exe, a2service.exe
ESET	eamonm.exe, eamsi.exe, ecls.exe, efwd.exe, egui.exe, eguiProxy.exe, ekrn.exe, ekrnEpfw.exe, ERAAgent.exe, EraAgentSvc.exe
Fortinet	firesvc.exe, firetray.exe, FortiTray.exe, fortiedr.exe, fw.exe
G DATA	GDDServer.exe, QHPISVR.EXE, QUHLPSVC.EXE, SAPISSVC.EXE
Heimdal	HeimdalsecurityAgent.exe
Huntress	HuntressAgent.exe, HuntressRMM.exe
Kaspersky	avp.exe, avpsus.exe, avpui.exe, kavfs.exe, kavfsscs.exe, kavfswb.exe, kavfswp.exe, kavtray.exe, klactprx.exe, klcsldcl.exe, klcsweb.exe, klnagent.exe, klnagchk.exe, klscctl.exe, klserver.exe, klwtblfs.exe, kpf4ss.exe, ksde.exe, ksdeui.exe, vapm.exe
LogRhythm	LogProcessorService.exe
McAfee/Trellix	AGMSvc.exe, AGSSvc.exe, masvc.exe, macmnsvc.exe, McAfeeAgent.exe, mcshield.exe, mfeann.exe, mfevtps.exe, mfetp.exe, mfepehost.exe, mfevfire.exe,



	mfemactl.exe, mfemacsvc.exe, mfemgr.exe, mfemms.exe, MgntSvc.exe, ModuleCoreService.exe, tepfsvc.exe
Microsoft Defender	MSASCui.exe, MSASCuiL.exe, MpDefenderCoreService.exe, MsMpEng.exe, MsMpSvc.exe, MsSense.exe, msascuil.exe, msseces.exe, NisSrv.exe, nissrv.exe, SecurityHealthService.exe, SecurityHealthSystray.exe, SenseCncProxy.exe, SenseIR.exe, SenseNdr.exe, SenseSampleUploader.exe, smartscreen.exe, windefend.exe
Morphisec	MorphisecService.exe
Norton/Symantec	ccApp.exe, ccSvcHst.exe, ccsvchst.exe, ns.exe, nsservice.exe, nortonsecurity.exe, rtvscan.exe, SepMasterService.exe, sepWscSvc64.exe, smc.exe, SmcGui.exe, snac.exe, SymCorpUI.exe, SymWSC.exe
OSSEC/Wazuh	ossec-agent.exe, wazuh-agent.exe
Palo Alto Networks (Traps/Cortex)	cortexService.exe, trapsagent.exe, trapsd.exe, Traps.exe
Panda Security	panda_url_filtering.exe, pavfnsrv.exe, pavsvr.exe, psanhost.exe, PSANHost.EXE, pselamsvc.EXE, PSUAMain.EXE, PSUAService.EXE, pangps.exe
Qualys	qualys-cloud-agent.exe, QualysAgent.exe
Rapid7	ir_agent.exe, rapid7_endpoint.exe
Red Canary	RedCanaryAgent.exe
Sangfor	CSAAgent.exe, CSASvc.exe, SangforAgent.exe, SangforCSA.exe, SangforEDR.exe, SangforInterface.exe,



	SangforMonitor.exe, SangforProtect.exe, SangforService.exe, SangforTray.exe, SangforUD.exe
SentinelOne	Sentinel.exe, SentinelAgent.exe, SentinelAgentWorker.exe, SentinelCtl.exe, SentinelHelperService.exe, SentinelMemoryScanner.exe, SentinelPowerShellExtension.exe, SentinelRanger.exe, SentinelServiceHost.exe, SentinelStaticEngine.exe, SentinelStaticEngineScanner.exe, SentinelUI.exe
SonicWall	SonicWallClientProtectionService.exe, swc_service.exe
Sophos	hmpalert.exe, McsAgent.exe, McsClient.exe, SavApi.exe, SAVAdminService.exe, SAVService.exe, SEDService.exe, SophosADSyncService.exe, SophosClean.exe, SophosCleanM64.exe, SophosFIMService.exe, SophosFS.exe, SophosHealth.exe, SophosLiveQueryService.exe, SophosMTR.exe, SophosMTRExtension.exe, SophosNetFilter.exe, SophosNtpService.exe, SophosOsquery.exe, SophosOsqueryExtension.exe, Sophos.PolicyEvaluation.Service.exe, SophosSafestore64.exe, SophosUI.exe, SophosUpdateMgr.exe, sophosav.exe, sophossp.exe, SSPService.exe
Tanium	TaniumClient.exe, TaniumCX.exe, tanclient.exe
ThreatLocker	ThreatLockerConsent.exe, threatlockerservice.exe, threatlockertray.exe



TrendAI	coreFrameworkHost.exe, coreServiceShell.exe, NTRTScan.exe, ntrtscan.exe, Ntrtscan.exe, OfcService.exe, ofcDdaSvr.exe, PccNTMon.exe, PccNt.exe, TISafe.exe, TISafeSvc.exe, TmCCSF.exe, tmicAgentSetting.exe, TMBMSRV.exe, Tmbmsrv.exe, tm_netsrv.exe, TmListen.exe, tmntsrv.exe, TmPfw.exe, tmproxy.exe, TmProxy.exe, TmPreFilter.exe, TmSSClient.exe, TmsalInstance64.exe, TmWscSvc.exe, VOneAgentConsole.exe, VOneAgentConsoleTray.exe
Uptycs	VectorAgent.exe, UptycsAgent.exe
Varonis	DatAdvantage.exe, VaronisAgent.exe
WatchGuard	wlcsservice.exe
Webroot	WRSa.exe, WRSkyClient.exe, WRSVC.exe, wrsa.exe
Windows Sysinternals	Sysmon.exe, Sysmon64.exe
Zscaler	zlclient.exe



Tactics, Techniques, and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Reconnaissance	T1595	Active Scanning
Initial Access	T1566	Phishing
	T1078.002	Domain Accounts
	T1133	External Remote Services
	T1190	Exploit Public- Facing Application
Execution	T1053.003	Cron
	T1106	Native API
	T1059.006	Python
	T1059	Command and Scripting Interpreter
	T1047	Windows Management Instrumentation
	T1204.002	Malicious File
	T1059.001	PowerShell
	T1569.002	Service Execution
	T1053.005	Scheduled Task
	T1059.003	Windows Command Shell
Persistence	T1543.003	Windows Service
	T1053.003	Cron
	T1078.002	Domain Accounts
	T1133	External Remote Services



Tactic	Technique ID	Technique Name
	T1136.002	Domain Account
	T1547.009	Shortcut Modification
	T1136	Create Account
	T1053.005	Scheduled Task
Privilege Escalation	T1543.003	Windows Service
	T1053.003	Cron
	T1068	Exploitation for Privilege Escalation
	T1484.002	Domain Trust Modification
	T1078.002	Domain Accounts
	T1547.009	Shortcut Modification
	T1053.005	Scheduled Task
Defense Evasion	T1484	Domain Policy Modification
	T1112	Modify Registry
	T1562	Impair Defenses
	T1497	Virtualization/Sandbox Evasion
	T1218	System Binary Proxy Execution
	T1550.001	Application Access Token
	T1553.002	Code Signing
	T1484.002	Domain Trust Modification
	T1078.002	Domain Accounts
	T1222	File and Directory Permissions Modification
	T1562.007	Disable or Modify Cloud Firewall
	T1550.003	Pass the Ticket



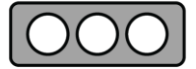
Tactic	Technique ID	Technique Name
	T1036.004	Masquerade Task or Service
	T1222.001	Windows File and Directory Permissions Modification
	T1014	Rootkit
	T1070.001	Clear Windows Event Logs
	T1036	Masquerading
	T1070.004	File Deletion
	T1484	Domain Policy Modification
	T1564.003	Hidden Window
Credential Access	T1539	Steal Web Session Cookie
	T1557.001	LLMNR/NBT-NS Poisoning and SMB Relay
	T1110	Brute Force
	T1110.003	Password Spraying
	T1110.001	Password Guessing
	T1003.001	LSASS Memory
	T1003	OS Credential Dumping
	T1003.004	LSA Secrets
	T1557.002	ARP Cache Poisoning
	T1555	Credentials from Password Stores
	T1003.003	NTDS
Discovery	T1087	Account Discovery
	T1135	Network Share Discovery
	T1497	Virtualization/Sandbox Evasion
	T1057	Process Discovery



Tactic	Technique ID	Technique Name
	T1033	System Owner/User Discovery
	T1615	Group Policy Discovery
	T1069.002	Domain Groups
	T1082	System Information Discovery
	T1083	File and Directory Discovery
	T1482	Domain Trust Discovery
	T1046	Network Service Discovery
	T1087.002	Domain Account
Lateral Movement	T1021.003	Distributed Component Object Model
	T1550.001	Application Access Token
	T1021.006	Windows Remote Management
	T1570	Lateral Tool Transfer
	T1021.004	SSH
	T1550.003	Pass the Ticket
	T1021.002	SMB/Windows Admin Shares
Collection	T1557.001	LLMNR/NBT-NS Poisoning and SMB Relay
	T1039	Data from Network Shared Drive
	T1560.001	Archive via Utility
	T1074.001	Local Data Staging
	T1557.002	ARP Cache Poisoning
Command and Control	T1071	Application Layer Protocol
	T1071.001	Web Protocols
	T1090	Proxy
	T1105	Ingress Tool Transfer



Tactic	Technique ID	Technique Name
	T1219	Remote Access Software
	T1572	Protocol Tunneling
Exfiltration	T1020	Automated Exfiltration
	T1041	Exfiltration Over C2 Channel
	T1048	Exfiltration Over Alternative Protocol
	T1048.001	Exfiltration Over Symmetric Encrypted Non C2 Protocol
	T1567	Exfiltration Over Web Service
Impact	T1486	Data Encrypted for Impact
	T1489	Service Stop
	T1490	Inhibit System Recovery
	T1491.001	Internal Defacement
	T1657	Financial Theft



Indicators of Compromise (IoCs)

Indicators of Compromise (IoCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IoCs ผ่านทางแพลตฟอร์ม MISIP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

SHA-1

8ae6bd18b129061f63642531f1b684cf0383c75d
ba914fe77b177b45799403b16dd14765c510a074
d605994fc72a2bb59b5cfb1624a1b9170eca73a2
5aa3124e5c4921e5edfc60133b5d71da21b07da3
f11aebccb9a86a7e2e653f90baec697f233c255f
ef9cd06683159397f099caa244e94e6eaad96eba
a11ee9cdc59e5caa59aefd27b30d104f3ad68e62
2f86898528c6cab3540c486a9bfaa0c029b73950
a19117175dbc9ba4d23b5dce8415e299a2e32192
d29670e684e40ddc89b47010c37cbc96737035b6
56bee9df5833a637f5c54d5911df98b0812fe643
cf4d74df17a91b4a36a2911b22afec5d8fa93a01
ec296f9501ad71e430810cb5cdc38d954d4ba536
7131b377e96016dc1911020c9f95b1b4d042d7b4
82ed942a52cdcf120a8919730e00ba37619661a3
f0537cbb773ae12100b36731e7c39f5a9d852b14
a5cf917ec4a7dfbdfa43621398604805d860c718
d4b19141102015d436321e6f26976e98183cfd27



SHA-256

95b46edaf566a13d118cb3452a65b024fddbcdcecf9cfa61269239cf1909c13
534bd6b99ed0e40ccbefad1656f03cc56dd9cc3f6d990cd7cb87af4cceebe144
36de8aae407b14bf910fb1a6b0e5604c7a5534eee2c2513e9d7742ef923ad665
b29f91a440527fb621d106a2048f6379fff3263c60aeda9c82ff8c1d5ae880a8
2d91a78e739891c9854c254f5b2a6b84c0e167dfa253466cbccd2cdd1c20145d
f6ee01303cf1d68015eee49f7dc7f26151a04ae642a47e49c70806931ce652d3
3414671bc9470a0cb007fec51c735fff91d4b29e588ef55518f9895e304419d3
16f83f056177c4ec24c7e99d01ca9d9d6713bd0497eedb777a3ffefa99c97f0
50f2cdf16f05da9253fa2d6eb60d5a42da14c02c551c0874c9e953d4119da69c
a48060443c8f6d3c5bb3c534bca442cc02b7308ebf7d35b2808c1f1300be99a4



แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- ตั้งค่า EDR หรือ SIEM ให้แจ้งเตือนเมื่อมีการติดตั้งหรือโหลดไดรเวอร์ระบบปฏิบัติการที่ผิดปกติ (BYOVD) โดยเฉพาะชื่อไฟล์หรือแฮชที่ตรงรายการ IoC หรือเมื่อมี Service ใหม่ถูกสร้างขึ้นโดยไม่ทราบสาเหตุ
- ตรวจสอบการใช้งานคำสั่ง Command Line หรือ PowerShell ที่มีพฤติกรรมน่าสงสัย เช่น การพยายามปิดการทำงานของระบบป้องกัน (Windows Defender, Antivirus) หรือคำสั่งลบ Shadow Copies (vssadmin.exe delete shadows /all /quiet)
- เฝ้าระวังการเปลี่ยนแปลงนโยบาย Group Policy (GPO) บน Domain Controller ที่ไม่ได้รับการอนุมัติ ซึ่งอาจเป็นสัญญาณของการเตรียมกระจายสคริปต์เพื่อติดตั้งมัลแวร์
- ตรวจสอบปริมาณการส่งออกข้อมูล (Outbound Traffic) ที่สูงผิดปกติไปยังบริการ CloudStorage สาธารณะ (เช่น Mega, Proton Drive) ซึ่งอาจเกิดจากการขโมยข้อมูล (Data Exfiltration)
- ตรวจสอบสัญญาณผิดปกติของ EDR/AV ที่หยุดทำงานเงียบ (Silent Failure) โดยตั้งค่า Alert ให้แจ้งเตือนในกรณีต่อไปนี้
 - Agent หยุดส่งข้อมูล Telemetry เกินระยะเวลาที่กำหนด (Heartbeat/Check-in Timeout)
 - Service ของผลิตภัณฑ์ Security ถูกหยุดการทำงาน (Service Stopped/Disabled) โดยไม่ได้รับอนุญาต

การป้องกัน (Prevention)

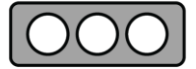
- ดำเนินการอัปเดตแพตช์ (Patch Management) อุปกรณ์รักษาความปลอดภัยและระบบปฏิบัติการให้เป็นเวอร์ชันล่าสุดอย่างสม่ำเสมอ โดยให้ความสำคัญสูงสุดกับช่องโหว่บนอุปกรณ์ที่เข้าถึงได้จากอินเทอร์เน็ต (Public-facing assets)
- บังคับใช้การยืนยันตัวตนแบบหลายปัจจัย (Multi-Factor Authentication - MFA) สำหรับทุกช่องทางการเข้าถึงระบบจากระยะไกล เช่น VPN, RDP หรือแอปพลิเคชันขององค์กร



- กำหนดนโยบาย Application Control หรือเปิดใช้งานไฟเจอร์ Block Vulnerable Drivers บนระบบปฏิบัติการและ EDR เพื่อป้องกันไม่ให้ผู้ไม่หวังดีสามารถโหลด ไดรเวอร์ ที่มีช่องโหว่เพื่อเข้ามาทำงานของระบบรักษาความปลอดภัยได้
- แบ่งส่วนเครือข่าย (Network Segmentation) อย่างชัดเจน โดยแยกเครือข่ายของเซิร์ฟเวอร์ที่สำคัญและระบบสำรองข้อมูล (Backup Systems) ออกจากเครือข่ายของพนักงานทั่วไปเพื่อจำกัดขอบเขตความเสียหายหากเกิดการแพร่ระบาด (Lateral Movement)
- จัดเก็บข้อมูลสำรองแบบออฟไลน์ (Offline Backup) หรือใช้เทคโนโลยี Immutable Backup ที่ไม่สามารถแก้ไขหรือลบได้ เพื่อให้มั่นใจว่าจะมีข้อมูลสำหรับกู้คืนระบบแม้ถูกโจมตีด้วย Ransomware

การรับมือ (Response)

- ตัดการเชื่อมต่อเครือข่าย (Isolate) เครื่องคอมพิวเตอร์และเซิร์ฟเวอร์ที่พบว่าติดเชื้อออกจากระบบเครือข่ายทันที ทั้งแบบใช้สายและไร้สาย แต่ห้ามปิดเครื่องเพื่อรักษาสถานะของหน่วยความจำ (RAM) สำหรับการตรวจพิสูจน์พยานหลักฐานทางดิจิทัล (Digital Forensics)
- ตรวจสอบหาต้นตอของการบุกรุก (Root Cause Analysis) และประเมินขอบเขตความเสียหาย โดยไล่ตรวจสอบบัญชีผู้ใช้งานที่ถูกนำมาใช้และพฤติกรรมเคลื่อนไหวในระบบ (Lateral movement) ผ่าน AD Logs เพื่อดูว่ามัลแวร์กระจายไปที่ใดบ้าง
- รวบรวมพยานหลักฐาน เช่น ไฟล์ Ransom Note, ตัวอย่างไฟล์ที่ ถูกเข้ารหัส, แอสของมัลแวร์ และ Log ที่เกี่ยวข้องกับการพยายามติดต่อกับ C2 Server เพื่อนำมาใช้สืบสวนและประสานงานกับหน่วยงานที่เกี่ยวข้อง
- ห้ามโอนเงินค่าไถ่ให้กับผู้โจมตีโดยเด็ดขาด เนื่องจากการจ่ายเงินไม่ได้เป็นเครื่องรับประกันว่าจะได้ข้อมูลคืน และยังเป็นการสนับสนุนกลุ่มอาชญากรทางไซเบอร์
- ดำเนินการล้างระบบและกู้คืนข้อมูล (Recovery) จากระบบสำรองข้อมูลที่ปลอดภัยและได้รับการตรวจสอบแล้วว่าไม่ติดมัลแวร์ ก่อนที่จะนำเครื่องกลับเข้าสู่เครือข่ายปกติ พร้อมทั้งเปลี่ยนรหัสผ่านของระบบและบัญชีทั้งหมดที่เกี่ยวข้อง



อ้างอิง (References)

1. Cyberint's Threat Actor Intelligence
2. ESET Research "Killing me gently: Inside Gentlemen's EDR killer framework"
<https://www.welivesecurity.com/en/eset-research/killing-me-gently-inside-gentlemens-edr-killer-framework/>
3. CSA labspace "GentleKiller: Inside the Gentlemen RaaS EDR-Killer Suite"
<https://labs.cloudsecurityalliance.org/research/csa-research-note-gentlekiller-edr-evasion-ransomware-defens/>
4. Trend micro "Unmasking The Gentlemen Ransomware: Tactics, Techniques, and Procedures Revealed"
https://www.trendmicro.com/en_us/research/25/i/unmasking-the-gentlemen-ransomware.html



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://dg.th/nsexlfob51>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th